

Information Systems and Controls

Study Framework
Slayer CPA

Generated February 26, 2026

Contents

Concept Maps

Decision Trees

Formula Sheet

Reference Tables

Mnemonics

Concept Maps

IT Infrastructure Layers

IT Infrastructure Stack

Hardware Layer

- | Servers, workstations, mobile devices
- | Storage (SAN, NAS, DAS)
- | Network hardware (routers, switches, firewalls)

Network Layer

- | LAN, WAN, VPN, WLAN
- | TCP/IP protocol stack
- | DNS, DHCP, load balancers

Operating System Layer

- | Resource management and process scheduling
- | User access and file system permissions
- | Patch management and hardening

Application Layer

- | ERP, CRM, financial reporting systems
- | Custom vs. commercial off-the-shelf (COTS)
- | SDLC controls and change management

Data Layer

- | Relational databases (SQL) and NoSQL
- | Data warehouses, data lakes, ETL processes
- | Encryption at rest and in transit

Cloud Computing Models — Shared Responsibility

Cloud Service Models

IaaS (Infrastructure as a Service)

- Provider manages: physical hardware, networking, virtualization
- Customer manages: OS, middleware, applications, data
- Examples: AWS EC2, Azure VMs, Google Compute Engine

PaaS (Platform as a Service)

- Provider manages: everything through runtime environment
- Customer manages: applications and data only
- Examples: Azure App Service, Google App Engine, Heroku

SaaS (Software as a Service)

- Provider manages: entire stack including application
- Customer manages: user access, configuration, data governance
- Examples: Salesforce, Microsoft 365, QuickBooks Online

Deployment Models

- Public — shared infrastructure, multi-tenant
- Private — dedicated infrastructure, single tenant
- Hybrid — mix of on-premises and cloud
- Community — shared by organizations with common concerns

NIST Cybersecurity Framework (CSF)

NIST CSF Core Functions

Identify

- Asset management — inventory all hardware, software, data
- Risk assessment — identify threats and vulnerabilities
- Governance — policies, procedures, regulatory requirements

Protect

- Access control — authentication and authorization
- Data security — encryption, DLP, classification
- Training — security awareness programs

Detect

- Continuous monitoring — SIEM, IDS/IPS, log analysis
- Anomaly detection — behavioral analytics, baselines
- Detection processes — defined and tested procedures

Respond

- Response planning — predefined incident response plans
- Communications — internal and external notification
- Mitigation — contain and limit the impact

Recover

- Recovery planning — restore systems and data
- Improvements — lessons learned, update procedures
- Communications — coordinate restoration with stakeholders

Access Control Models

Access Control Frameworks

DAC (Discretionary Access Control)

- Owner of resource sets permissions
- Flexible but less secure
- Example: file system permissions set by file owner

MAC (Mandatory Access Control)

- System-enforced based on classification labels
- Users cannot change access rights
- Example: military/government classified systems

RBAC (Role-Based Access Control)

- Permissions assigned to roles, users assigned to roles
- Supports least privilege and segregation of duties
- Most common in enterprise environments

ABAC (Attribute-Based Access Control)

- Decisions based on user, resource, and environment attributes
- Highly granular and context-aware
- Example: allow access only during business hours from corp network

SOC Engagement Types

System and Organization Controls (SOC) Reports

SOC 1

- Focus: controls relevant to user entities' financial reporting (ICFR)
- Governed by SSAE 18 / AT-C 320
- Audience: user entities and their auditors

SOC 2

- Focus: Trust Services Criteria (SAPCP)
- Governed by AT-C 205
- Audience: management, regulators, specified parties (restricted)

SOC 3

- Focus: same as SOC 2 but general-use report
- No detailed testing results — summary only
- Audience: general public (marketing, website seal)

Type I vs. Type II

- Type I — design of controls at a point in time
- Type II — design and operating effectiveness over a period (typically 6-12 months)
- Type II provides more assurance than Type I

Trust Services Criteria (TSC)

AICPA Trust Services Criteria

Security (Common Criteria — required for all SOC 2)

- Protection against unauthorized access
- Firewalls, IDS/IPS, access controls, encryption
- Foundation for all other criteria

Availability

- System is available for operation and use as committed
- BCP/DR planning, SLAs, monitoring, redundancy

Processing Integrity

- Processing is complete, valid, accurate, timely, authorized
- Input validation, reconciliation, error handling

Confidentiality

- Information designated as confidential is protected
- Encryption, access restrictions, NDAs, data classification

Privacy

- Personal information collected, used, retained, disclosed per notice
- Consent, data minimization, subject rights, breach notification

Incident Response Lifecycle

NIST SP 800-61 Incident Response

Preparation

- Establish IR team, policies, tools, and communication plans
- Conduct tabletop exercises and simulations

Identification

- Detect and confirm the incident
- Classify severity and scope
- Activate IR team and begin documentation

Containment

- Short-term: isolate affected systems immediately
- Long-term: apply temporary fixes, preserve evidence

Eradication

- Remove root cause (malware, compromised accounts)
- Patch vulnerabilities that were exploited

Recovery

- Restore systems from clean backups
- Verify system integrity before returning to production
- Monitor for signs of recurrence

Lessons Learned

- Post-incident review within 1-2 weeks
- Document findings and update IR plan
- Improve controls to prevent recurrence

Data Lifecycle Management

Data Lifecycle Stages

Creation / Collection

- Classify data at point of creation
- Apply ownership and labeling

Storage

- Encryption at rest, access controls
- Redundancy and backup procedures

Use / Processing

- Enforce least privilege during processing
- Input validation, output controls

Sharing / Transfer

- Encryption in transit (TLS, VPN)
- Third-party agreements, DLP controls

Archival

- Retention policies aligned to legal/regulatory requirements
- Secure offline or cold storage

Destruction

- Cryptographic erasure, degaussing, physical destruction
- Certificate of destruction for compliance

IT General Controls (ITGCs)

IT General Controls

Logical Access Controls

- Authentication (passwords, MFA, biometrics)
- Authorization (RBAC, least privilege)
- Provisioning and deprovisioning
- Periodic access recertification

Program Change Controls

- Change request and CAB approval
- Testing (unit, integration, UAT)
- Segregation of dev/test/production
- Emergency change retroactive approval

Computer Operations Controls

- Job scheduling and batch processing
- Backup (full, incremental, differential)
- System monitoring and alerting
- Capacity and performance management

System Development Controls

- SDLC methodology and phases
- Version control and code review
- Security testing before deployment

Decision Trees

Which SOC Report Type to Use

Are the controls relevant to user entities' internal control over financial reporting (ICFR)?

Yes: Do you need to evaluate operating effectiveness of controls over a period of time?

Yes: SOC 1 Type II — controls relevant to ICFR, tested over a period (6-12 months)

No: SOC 1 Type I — controls relevant to ICFR, design evaluated at a point in time

No: Is the report intended for a restricted audience (management, regulators, specified parties)?

Yes: Do you need to evaluate operating effectiveness of controls over a period of time?

Yes: SOC 2 Type II — Trust Services Criteria, tested over a period (highest assurance)

No: SOC 2 Type I — Trust Services Criteria, design evaluated at a point in time

No: SOC 3 — general-use summary report on Trust Services Criteria (suitable for public distribution)

Cloud Deployment Model Selection

Does the organization require full control over physical infrastructure and data sovereignty?

Yes: On-premises — maximum control, highest cost, organization manages everything

No: **Does the organization need to manage the OS, middleware, and runtime environment?**

Yes: IaaS — provider manages hardware/networking; customer manages OS through applications

No: **Does the organization need to deploy and manage custom application code?**

Yes: PaaS — provider manages through runtime; customer manages application code and data

No: SaaS — provider manages entire stack; customer manages configuration and user access only

Encryption Method Selection

Is the data at rest (stored)?

Yes: **Do you need to query or search individual fields within the encrypted data?**

Yes: Column-level / field-level encryption (AES-256) — encrypt sensitive columns individually; allows querying non-encrypted fields

No: Full-disk or volume encryption (AES-256, BitLocker, LUKS) — encrypts entire storage volume transparently; best for laptops, servers, cloud volumes

No: **Is the communication between two parties who have not previously exchanged keys?**

Yes: Asymmetric encryption (RSA/ECC) for key exchange, then symmetric (AES) for session — TLS/HTTPS

No: Symmetric encryption with pre-shared key — VPN tunnels, internal network communication

Disaster Recovery Site Selection

Does the organization require near-zero downtime (RTO measured in minutes)?

Yes: Hot site — fully operational duplicate environment, data synchronized in real-time, highest cost

No: **Can the organization tolerate downtime of several hours (RTO measured in hours)?**

Yes: Warm site — partially configured with hardware, requires data restoration, moderate cost

No: Cold site — empty facility with power/connectivity only, requires full setup, lowest cost, RTO in days

Privacy Regulation Applicability

Does the organization process personal data of EU/EEA residents?

Yes: GDPR applies — consent or legal basis required, data subject rights, 72-hour breach notification, DPO may be required

No: **Does the organization collect personal information of California residents and meet revenue/data thresholds?**

Yes: CCPA/CPRA applies — right to know, delete, opt-out of sale; no private right of action except for breaches

No: **Does the organization handle protected health information (PHI) as a covered entity or business associate?**

Yes: HIPAA applies — Privacy Rule, Security Rule, Breach Notification Rule; BAAs required with business associates

No: General data protection best practices apply — monitor for state-specific privacy laws and industry regulations

Is This Change Properly Authorized?

Was a formal change request submitted?

- Yes:** Was the change reviewed and approved by the CAB (or delegated authority)?
 - Yes:** Was the change tested in a non-production environment before deployment?
 - Yes:** Was the migration to production performed by someone other than the developer?
 - Yes:** Properly authorized change — document and close the change ticket
 - No:** SoD violation — developer should not migrate their own code to production
 - No:** Control gap — all changes must be tested before deployment, even if approved
 - No:** Unauthorized change — route back through CAB approval process
- No:** Was this an emergency change to address a critical outage?
 - Yes:** Acceptable if retroactively documented, tested, and approved by CAB within the defined timeframe
 - No:** Unauthorized change — must follow the standard change control process

SOC Test Type Selection

Is the control automated (system-enforced configuration)?

- Yes:** Are IT general controls (change management, access controls) over the system effective?
 - Yes:** Inspect configuration + limited reperformance (one test may suffice — automated control operates consistently when ITGCs effective)
 - No:** Cannot rely on consistency of automated control — test like a manual control with sampling across the period, plus investigate ITGC failures
- No:** Does the control produce documentary evidence (logs, signatures, reports)?
 - Yes:** Is the control high-risk or were there prior-period exceptions?
 - Yes:** Inspection of documentation with larger sample size + consider reperformance for complex controls; spread sample across full period
 - No:** Inspection of documentation with standard sample size spread across the examination period; corroborate with inquiry
 - No:** Observation of the control being performed + inquiry of personnel; note that observation only provides point-in-time evidence — combine with other procedures

Formula Sheet

Recovery Point Objective (RPO)	$RPO = \text{Maximum tolerable data loss (measured in time)}$	The maximum acceptable amount of data loss measured in time. RPO of 1 hour means backups must occur at least hourly. Drives backup frequency decisions.
Recovery Time Objective (RTO)	$RTO = \text{Maximum tolerable downtime (measured in time)}$	The maximum acceptable time to restore systems after a disruption. RTO of 4 hours means systems must be operational within 4 hours. Drives DR site selection.
Annualized Loss Expectancy (ALE)	$ALE = SLE \times ARO$	Single Loss Expectancy (SLE = asset value x exposure factor) times Annualized Rate of Occurrence (ARO). Used to justify security spending: implement control if cost < ALE reduction.
Single Loss Expectancy (SLE)	$SLE = \text{Asset Value} \times \text{Exposure Factor (EF)}$	Expected monetary loss each time a risk event occurs. Exposure factor is the percentage of asset value lost (0 to 1).
Risk Calculation	$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$	Qualitative or quantitative risk assessment. Threat is the probability of an attack, vulnerability is the likelihood of exploitation, impact is the resulting damage.

Reference Tables

NIST CSF Functions and Categories

Function	Key Categories	Purpose
Identify	Asset Management, Risk Assessment, Governance	Understand the organizational context and risk landscape
Protect	Access Control, Data Security, Training, Maintenance	Implement safeguards to ensure service delivery
Detect	Anomalies & Events, Continuous Monitoring, Detection Processes	Identify cybersecurity events in a timely manner
Respond	Response Planning, Communications, Mitigation, Analysis	Take action on detected cybersecurity events
Recover	Recovery Planning, Improvements, Communications	Restore capabilities impaired by cybersecurity events

SOC Report Comparison

Feature	SOC 1	SOC 2	SOC 3
Focus	Controls over financial reporting (ICFR)	Trust Services Criteria (SAPCP)	Trust Services Criteria (summary)
Standard	SSAE 18 / AT-C 320	AT-C 205	AT-C 205
Audience	User entities and their auditors	Management, regulators, specified parties	General public
Distribution	Restricted	Restricted	General use
Type I	Design at a point in time	Design at a point in time	N/A (Type II only)
Type II	Design + effectiveness over a period	Design + effectiveness over a period	Short-form report based on SOC 2 Type II
Typical period	6-12 months	6-12 months	Same period as companion SOC 2 Type II

Privacy Regulation Comparison

Feature	GDPR	CCPA/CPRA	HIPAA
Jurisdiction	EU/EEA residents	California residents	US healthcare (covered entities and BAs)
Data covered	All personal data	Personal information linked to consumer/household	Protected health information (PHI)
Legal basis required	Yes (consent, contract, legitimate interest, etc.)	No (opt-out model)	Treatment, payment, operations (no consent for TPO)
Right to delete	Yes (right to erasure)	Yes	Limited (amendment, not deletion)
Breach notification	72 hours to supervisory authority	Without unreasonable delay	60 days to individuals, HHS, and media if >500
Penalties	Up to 4% of global annual revenue or EUR 20M	\$2,500 per violation; \$7,500 if intentional	\$100-\$50,000 per violation; \$1.5M annual cap per category

Encryption Comparison

Feature	Symmetric (AES)	Asymmetric (RSA/ECC)
Keys	Single shared key	Public/private key pair

Speed	Fast — suitable for bulk data	Slow — computationally intensive
Key distribution	Challenge — must securely share key	Easier — public key can be freely distributed
Common algorithms	AES-128, AES-256, 3DES	RSA-2048, RSA-4096, ECC
Primary use	Data at rest, session encryption	Key exchange, digital signatures, authentication
TLS/HTTPS	Session data encryption (after handshake)	Initial key exchange (handshake phase)

Control Types and Functions

Type	Timing	Purpose	Examples
Preventive	Before the event	Stop threats from occurring	Firewalls, access controls, encryption, segregation of duties, input validation
Detective	During/after the event	Identify that a threat has occurred	IDS/IPS, log monitoring, audit trails, reconciliations, SIEM alerts
Corrective	After the event	Remediate the impact of a threat	Backups/restore, patch deployment, incident response, antivirus quarantine
Deterrent	Before the event	Discourage potential threats	Warning banners, security cameras, acceptable use policies, penalties
Compensating	Varies	Substitute when primary control is not feasible	Manual review when automated control fails, additional monitoring

Malware Types and Characteristics

Type	Behavior	Propagation	Key Characteristic
Virus	Attaches to legitimate programs	Requires user action (execute infected file)	Cannot self-replicate without host program
Worm	Self-replicating standalone program	Spreads automatically across networks	No host program needed; consumes bandwidth
Trojan	Disguised as legitimate software	Requires user to install	Creates backdoors; no self-replication
Ransomware	Encrypts victim's files	Phishing, exploit kits, RDP	Demands payment for decryption key
Spyware	Monitors user activity secretly	Bundled with software, drive-by download	Keyloggers, screen capture, credential theft
Rootkit	Hides deep in OS to maintain access	Exploits or bundled with other malware	Extremely difficult to detect; modifies OS kernel

IT Governance Frameworks Comparison

Dimension	COBIT 2019	ITIL 4	NIST RMF	COSO
Primary focus	IT governance and management	IT service management	Information security risk	Internal control over financial reporting
Issued by	ISACA	Axelos/PeopleCert	NIST (U.S. government)	COSO (Treadway Commission)
Key structure	5 domains (EDM, APO, BAI, DSS, MEA)	Service Value System + 34 practices	7 steps (Prepare through Monitor)	5 components (Control environment through Monitoring)
Maturity model	6 levels (0-5) CMMI-based	N/A — uses continual improvement	N/A — uses FIPS 199 categorization	N/A — uses effectiveness assessment
CPA exam relevance	IT governance questions	Service management concepts	IT risk assessment	ICFR evaluation (primary framework)

SOC Opinion Types and Conditions

Opinion Type	Condition	Report Language	User Impact
--------------	-----------	-----------------	-------------

Unqualified (clean)	Description fairly presented; controls suitably designed and operating effectively (Type II); no material exceptions	'In our opinion, the description is fairly presented... and the controls... were suitably designed and operating effectively'	Highest assurance — user auditor can rely on SOC report for the controls tested
Qualified	One or more material exceptions limited to specific controls; overall control environment is still effective	'Except for [specific control(s)]... the controls were suitably designed and operating effectively'	User auditor evaluates the impact of the excepted controls on their risk assessment; may need additional procedures for affected areas
Adverse	Exceptions are pervasive across multiple control areas; the control environment as a whole is not effective	'The controls were not suitably designed / not operating effectively to achieve the applicable criteria'	User auditor cannot rely on the SOC report; must perform alternative procedures or expand substantive testing significantly
Disclaimer	Practitioner unable to obtain sufficient appropriate evidence (scope limitation imposed by service organization or circumstances)	'We were unable to obtain sufficient appropriate evidence to form an opinion'	No assurance provided; user auditor must treat as if no SOC report exists and perform full alternative procedures

Mnemonics

SAPCP

Security, Availability, Processing Integrity, Confidentiality, Privacy

The five Trust Services Criteria used in SOC 2 engagements. Security (common criteria) is always required; the other four are optional based on engagement scope.

IPDRR

Identify, Protect, Detect, Respond, Recover

The five core functions of the NIST Cybersecurity Framework, in order. Remember: 'I Protect, Detect, Respond, Recover.'

CIA

Confidentiality, Integrity, Availability

The three pillars of information security. Confidentiality = prevent unauthorized disclosure. Integrity = prevent unauthorized modification. Availability = ensure authorized access when needed.

RICE

Request, Incident, Change, Event

The four core change management process types in IT service management. All changes must go through a formal change advisory board (CAB) review before implementation.

PICERL

Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned

The six phases of incident response per NIST SP 800-61. Memory aid: 'Please Identify, Contain, Eradicate, Recover, Learn.'

KHA

Knowledge (something you know), Have (something you have), Are (something you are)

The three authentication factors. Knowledge = password/PIN. Have = token/smart card/phone. Are = biometrics (fingerprint, retina). MFA requires two or more different factors.

DRMM

DAC, RBAC, MAC, (A)BAC

The four access control models from least to most restrictive: Discretionary (owner decides), Role-Based (role determines access), Mandatory (classification labels), Attribute-Based (policies evaluate multiple attributes).

HWC

Hot site, Warm site, Cold site

DR site types from fastest to slowest recovery. Hot = real-time sync, minutes RTO, highest cost. Warm = partial hardware, hours RTO. Cold = empty facility, days RTO, lowest cost.

APOC

Access controls, Program change controls, Operations controls, Creation/development controls

The four categories of IT General Controls (ITGCs). All automated application controls depend on these ITGCs being effective.